

RAPPORT PENTEST ODOO

ccdoc

Introduction

Dans le cadre de la sécurisation de la plateforme Odoo interne, un test d'intrusion a été mené afin d'évaluer le niveau de sécurité de l'application et de son environnement d'hébergement. Cette évaluation avait pour objectif d'identifier les vulnérabilités techniques et applicatives pouvant compromettre la confidentialité, l'intégrité ou la disponibilité des données internes.

Il est important de préciser que les tests ayant conduit à l'énumération et au dump de 34 modèles Odoo ont été réalisés à l'aide de comptes utilisateurs valides (email et mot de passe), fournis dans le cadre de la mission.

Les actions ont été effectuées sans privilèges administrateur et en utilisant uniquement les droits associés à un utilisateur interne standar.

Le présent rapport détaille , les vulnérabilités identifiées sur la plateforme Odoo, leur impact potentiel, ainsi que les recommandations nécessaires pour renforcer la sécurité globale du système.

Vulnérabilités

Au cours du test d'intrusion réalisé sur la plateforme Odoo interne, l'outil OdooMap a permis d'énumérer 34 modèles accessibles sur 200 testés, avec la possibilité d'en extraire le contenu (*dump*).

Malgré une authentification légitime, l'utilisateur disposait de la capacité de :

- lister un grand nombre de modèles internes,
- accéder à des modèles critiques (comptabilité, partenaires, ventes, projets),
- extraire des données sans restriction fonctionnelle ou métier.

Ce comportement n'est pas conforme aux bonnes pratiques de sécurité Odoo.

Les modèles accessibles incluent notamment :

- **Finance / Comptabilité**
account.account, account.move, account.journal, account.tax,
account.analytic.account, account.fiscal.position.account,
account.journal.group, account.account.tag

- **Clients / Partenaires**
res.partner, res.partner.bank, res.company
- **Ventes / Achats / CRM**
sale.order, purchase.order, crm.lead, crm.team, crm.team.member
- **Stocks / Logistique**
stock.move, stock.scrap, stock.picking
- **Produits / Tarification**
product.product, product.template, product.category, product.pricelist
- **Projets / Activités**
project.project, project.task, project.milestone, project.update,
mail.activity, mail.activity.type, calendar.event
- **Sécurité / Configuration**
res.groups, res.users.apikeys.description, auth_totp.wizard

Cette exposition démontre un défaut majeur de contrôle d'accès sur les modèles Odoo via les interfaces RPC.

Preuve de Concept (PoC)

1. Modeles accessibles

```
[*] Testing access to 200 models... (change limit with -l limit)
[+] Found accessible model: account.account
[+] Found accessible model: account.analytic.account
[+] Found accessible model: res.partner.bank
[+] Found accessible model: calendar.event
[+] Found accessible model: res.company
[+] Found accessible model: res.partner
[+] Found accessible model: iap.account
[+] Found accessible model: account.journal
[+] Found accessible model: account.move
[+] Found accessible model: crm.lead
[+] Found accessible model: stock.lot
[+] Found accessible model: product.pricelist
[+] Found accessible model: product.template
[+] Found accessible model: product.category
[+] Found accessible model: product.product
[+] Found accessible model: project.project
[+] Found accessible model: project.milestone
[+] Found accessible model: project.update
[+] Found accessible model: purchase.order
[+] Found accessible model: sale.order
[+] Found accessible model: crm.team
[+] Found accessible model: crm.team.member
[+] Found accessible model: stock.scrap
[+] Found accessible model: project.task
[+] Found accessible model: account.tax
[+] Found accessible model: stock.picking
[+] Found accessible model: auth_totp.wizard
[+] Found accessible model: res.users.apikeys.description
[+] Found accessible model: res.groups
[+] Found accessible model: account.journal.group
[+] Found accessible model: account.account.tag
[+] Found accessible model: account.fiscal.position.account
[+] Found accessible model: mail.activity
[+] Found accessible model: mail.activity.type
[*] Testing model 200/200: account.analytic.distribution.model
[+] Found 34 accessible models out of 200 tested

[+] Model list saved to models.txt
```

Accessible Models

2. Dump des modeles

```

*] Reading model list from file: models.txt
*] Dumping data from 34 model(s) listed in file: models.txt
*] Dumping account.account to dump/account.account.json
*] Total records in account.account: 0
[!] No records found in account.account
*] Dumping account.analytic.account to dump/account.analytic.account.json
*] Total records in account.analytic.account: 0
[!] No records found in account.analytic.account
*] Dumping res.partner.bank to dump/res.partner.bank.json
*] Total records in res.partner.bank: 0
[!] No records found in res.partner.bank
*] Dumping calendar.event to dump/calendar.event.json
*] Total records in calendar.event: 1
*] Retrieved 1 records from calendar.event (Change limit with -l limit)
*] Data saved to dump/calendar.event.json

*] Dumping res.company to dump/res.company.json
*] Total records in res.company: 1
*] Retrieved 1 records from res.company (Change limit with -l limit)
*] Data saved to dump/res.company.json

*] Dumping res.partner to dump/res.partner.json
*] Total records in res.partner: 43
[-] Error dumping data from res.partner: <Fault 4: "Vous n'êtes pas autorisé à modifier l
ez votre administrateur pour demander l'accès si nécessaire.">
*] Dumping iap.account to dump/iap.account.json
*] Total records in iap.account: 2
*] Retrieved 2 records from iap.account (Change limit with -l limit)
*] Data saved to dump/iap.account.json

```

Dump Models

```

(sas_tjsta@sastesta) ~/odooapp/dump
$ ls
account.account.tag.json  calendar.event.json  crm.team.member.json  mail.activity.type.json  product.pricelist.json  project.project.json  purchase.order.json  stock.picking.json
account.tax.json          crm.team.json        iap.account.json       product.category.json    product.template.json   project.task.json     res.company.json

```

Models Dumper

3. Contenu de quelques modeles

```
cat /usr/share/mailadmin/3.0.0/crm.team.member.json
{
  "id": 1,
  "message_is_follower": false,
  "message_follower_ids": [],
  "message_partner_ids": [],
  "message_ids": [
    3
  ],
  "has_message": true,
  "message_needaction": false,
  "message_needaction_counter": 0,
  "message_has_error": false,
  "message_has_error_counter": 0,
  "message_attachment_count": 0,
  "message_main_attachment_id": false,
  "website_message_ids": [],
  "message_has_sms_error": false,
  "crm_team_id": [
    1,
    "Sales"
  ],
  "user_id": [
    2,
    "Administrator"
  ],
  "user_in_teams_ids": [
    2
  ],
  "user_company_ids": [
    1
  ],
  "active": true,
  "is_membership_multi": true,
  "member_warning": false,
  "image_1920": false,
  "image_128": false,
  "name": "Administrator",
  "email": "mimicolle333@gmail.com",
  "phone": false,
  "mobile": false,
  "company_id": [
    1,
    "Colombe Cyber Defense Operations Center SA"
  ]
}
```

Découverte du Mail Admin


```

    "Certificat PCI DSS"
  ],
  "product_variant_count": 1,
  "barcode": false,
  "default_code": false,
  "pricelist_item_count": 0,
  "can_image_1024_be_zoomed": false,
  "has_configurable_attributes": false,
  "product_tooltip": "Facturez les quantit\u00e9s command\u00e9es d\u00e9s que ce service est vendu.",
  "priority": "0",
  "product_tag_ids": [],
  "__last_update": "2026-02-02 09:13:07",
  "display_name": "Certificat PCI DSS",
  "create_uid": [
    6,
    "Rokhaya FAYE"
  ],
  "create_date": "2026-02-02 09:12:54",
  "write_uid": [
    6,
    "Rokhaya FAYE"
  ],
],

```

Fichiers des produits

```

"message_attachment_count": 0,
"message_main_attachment_id": false,
"website_message_ids": [],
"message_has_sms_error": false,
"name": "Core Switch",
"sequence": 1,
"description": false,
"description_purchase": false,
"description_sale": false,
"detailed_type": "consu",
"type": "consu",
"categ_id": [
  9,
  "\u00c9QUIPEMENT"
],
"currency_id": [
  42,
  "XOF"
],
"cost_currency_id": [
  42,
  "XOF"
]

```

Fichier produit 1

```

},
"has_message": true,
"message_needaction": false,
"message_needaction_counter": 0,
"message_has_error": false,
"message_has_error_counter": 0,
"message_attachment_count": 0,
"message_main_attachment_id": false,
"website_message_ids": [],
"message_has_sms_error": false,
"name": "Palo alto(Filewall, console de management,SDWAN )",
"sequence": 1,
"description": false,
"description_purchase": false,
"description_sale": false,
"detailed_type": "consu",
"type": "consu",
"categ_id": [
    4,
    "Licences"
]

```

Fichier produit 2

```

"message_needaction": false,
"message_needaction_counter": 0,
"message_has_error": false,
"message_has_error_counter": 0,
"message_attachment_count": 0,
"message_main_attachment_id": false,
"website_message_ids": [],
"message_has_sms_error": false,
"name": "Panneau de Brassages",
"sequence": 1,
"description": false,
"description_purchase": false,
"description_sale": false,
"detailed_type": "consu",
"type": "consu",
"categ_id": [
    9,
    "\u00c9QUIPEMENT"
],
"currency_id": [
    42,
    "XOF"
]

```

Fichier produit 3

```

"message_needaction": false,
"message_needaction_counter": 0,
"message_has_error": false,
"message_has_error_counter": 0,
"message_attachment_count": 0,
"message_main_attachment_id": false,
"website_message_ids": [],
"message_has_sms_error": false,
"access_url": "/my/purchase/3",
"access_token": false,
"access_warning": "",
"name": "P00003",
"priority": "0",
"origin": false,
"partner_ref": false,
"date_order": "2026-02-03 08:53:51",
"date_approve": false,
"partner_id": [
    53,
    "STARLINK"
],
"dest_address_id": false,

```

Ventes

```

"En attente de validation"
],
"update_ids": [],
"last_update_id": false,
"last_update_status": "to_define",
"last_update_color": 0,
"milestone_ids": [],
"milestone_count": 0,
"milestone_count_reached": 0,
"is_milestone_exceeded": false,
"__last_update": "2026-02-02 10:00:03",
"display_name": "Opportunit\u00e9 de DIRTRANS [CYBER]",
"create_uid": [
    2,
    "Administrator"
],
"create_date": "2026-02-01 21:18:29",
"write_uid": [
    6,
    "Rokhaya FAYE"
],
"write_date": "2026-02-02 10:00:03",

```

Projets

```

    "Alias inactif"
  ],
  "access_url": "/my/projects/10",
  "access_token": false,
  "access_warning": "",
  "name": "R\u00e9aménagement et s\u00e9curisation de deux locaux techniques + Module GSM Fire Alarm",
  "description": false,
  "active": true,
  "sequence": 10,
  "partner_id": [
    29,
    "Direction General de Comptabilit\u00e9 et du Tr\u00e9sor Publique DGCTP"
  ],
  "partner_email": false,
  "partner_phone": false,
  "commercial_partner_id": [
    29,
    "Direction General de Comptabilit\u00e9 et du Tr\u00e9sor Publique DGCTP"
  ],
],

```

Projets 2

```

"active": true,
"is_membership_multi": true,
"member_warning": false,
"image_1920": false,
"image_128": false,
"name": "Andr\u00e9 Louis Latyr DIOUF",
"email": "adiouf@ccdocsn.com",
"phone": false,
"mobile": false,
"company_id": [
  1,
  "Colombe Cyber Defense Operations Center SA"
],
"__last_update": "2026-01-30 10:31:51",
"display_name": "Andr\u00e9 Louis Latyr DIOUF",
"create_uid": [
  6,
  "Rokhaya FAYE"
],
"create_date": "2026-01-30 10:31:51",
"write_uid": [
  6,

```

Mail utilisateur

```

"user_company_ids": [
  1
],
"active": true,
"is_membership_multi": true,
"member_warning": false,
"image_1920": false,
"image_128": false,
"name": "Yaramé Di\u00e9ye",
"email": "ydieye@ccdocsn.com",
"phone": false,
"mobile": false,
"company_id": [
  1,
  "Colombe Cyber Defense Operations Center SA"
],
"__last_update": "2026-01-30 10:31:51",
"display_name": "Yaramé Di\u00e9ye",
"create_uid": [
  6,

```

Mail utilisateur 2

```

{
  "id": 7,
  "login": "afall@ccdoc-sn.com",
  "name": "Amadou FALL",
  "email": "afall@ccdoc-sn.com",
  "groups_id": [
    2,
    12,
    8,
    23,
    38,
    46,
    62,
    16,
    28,
    30,
    9
  ]
}

```

Mail utilisateur 3

```
},
{
  "id": 16,
  "login": "dskouak@ccdodoc-sn.com",
  "name": "Damigou Sandrine Kouak",
  "email": "dskouak@ccdodoc-sn.com",
  "groups_id": [
    12,
    8,
    38,
    16,
    9,
    20,
    1,
    14,
    13,
    18,
    19,
    6,
    34,
```

Mail utilisateur 4

```
},
{
  "id": 8,
  "login": "mfall@ccdodoc-sn.com",
  "name": "Mouhamed FALL",
  "email": "mfall@ccdodoc-sn.com",
  "groups_id": [
    12,
    8,
    62,
    16,
    28,
    30,
    9,
    20,
    1,
```

Mail utilisateur 5

```
{
  "id": 20,
  "login": "mondiaye@ccdoc-sn.com",
  "name": "Mouhamed NDIAYE",
  "email": "mondiaye@ccdoc-sn.com",
  "groups_id": [
    12,
    8,
    16,
    9,
    20,
    1,
    14,
```

Mail utilisateur 6

```
{
  "id": 21,
  "login": "Odooc@ccdocsn.com",
  "name": "Odooc",
  "email": "Odooc@ccdocsn.com",
  "groups_id": [
    2,
    12,
    8,
    23,
    38,
    62,
```

Mail utilisateur 7

```
"id": 11,
"login": "odrame@ccdoc-sn.com",
"name": "Ousmane DRAME",
"email": "odrame@ccdoc-sn.com",
"groups_id": [
  12,
  8,
  62,
  16,
  28,
  30,
```

Mail utilisateur 8

Impacts et risques

1. Compromission des données financières (Critique)

L'accès aux modèles comptables permet :

- la consultation des écritures comptables,
- l'identification des journaux financiers,
- l'accès aux taxes, comptes analytiques et positions fiscales.

Risque direct : fuite de données financières sensibles, fraude interne, non-conformité réglementaire.

2. Exposition des données clients, fournisseurs et employés

Les modèles res.partner, res.partner.bank, res.company permettent :

- l'extraction d'informations personnelles et bancaires,
- l'identification des partenaires stratégiques,
- la cartographie de l'organisation interne.

Risque : violation de la confidentialité, exploitation à des fins de fraude ou d'ingénierie sociale.

3. Accès aux opérations commerciales et stratégiques

Les modèles sale.order, purchase.order, crm.lead, project.project exposent :

- le pipeline commercial,
- les projets en cours,
- les priorités business et contrats actifs.

Risque : espionnage économique, avantage concurrentiel indu, manipulation des opérations.

4. Atteinte à l'intégrité du système d'information

Même si le test s'est limité à la lecture, l'accès à ces modèles ouvre la voie à :

- des modifications non autorisées,
- des suppressions de données critiques,
- une perturbation de la production (stocks, facturation, projets).

Risque d'escalade de privilèges

L'accès aux modèles `res.groups` et `res.users.apikeys.description` permet :

- la compréhension fine du modèle de rôles,
- l'identification des mécanismes d'authentification (API keys, TOTP).

Risque : élévation de privilèges et compromission complète de la plateforme.

5. Non-conformité aux standards de sécurité

Cette vulnérabilité correspond à :

- **OWASP Top 10 – A01 : Broken Access Control**
- violation du principe de **moindre privilège**
- non-respect des bonnes pratiques de sécurité Odoo.

Recommandations et mesures correctives

1. Revue immédiate des ACL (`ir.model.access`)

- Supprimer tout accès inutile en lecture sur :
 - modèles comptables,
 - modèles RH / partenaires,
 - modèles de configuration et de sécurité.
- Vérifier les droits accordés aux groupes par défaut (Employee, User).

2. Mise en place de Record Rules strictes

- Restreindre l'accès aux données selon :
 - l'utilisateur,
 - l'équipe,
 - l'entité (res.company).
- Tester les règles avec des comptes à privilèges minimaux.

3. Sécurisation des accès RPC (XML-RPC / JSON-RPC)

- Restreindre l'exposition des méthodes génériques (search, read, search_read)
- Bloquer l'accès RPC aux utilisateurs non nécessaires.
- Limiter les appels API aux IP internes ou de confiance.

4. Protection renforcée des modèles sensibles

- Désactiver l'accès direct aux modèles critiques :
 - account.*, res.groups, res.users.*
- Utiliser des vues et services intermédiaires contrôlés.

5. Journalisation et détection

- Activer la surveillance des appels RPC :
 - détection d'énumération de modèles,
 - détection de dump massif de données.
- Mettre en place des alertes SOC.

Références techniques pour l'implémentation des recommandations

1. Renforcement des contrôles d'accès (ACL – ir.model.access)

La mise en place de contrôles d'accès stricts au niveau des modèles permet de limiter les opérations (read, write, create, unlink) aux seuls groupes d'utilisateurs autorisés.

Documentation officielle Odoo :

Odoo – Sécurité backend (Access Control Lists et Record Rules)

<https://www.odoo.com/documentation/19.0/fr/developer/reference/backend/security.html>

Cette documentation explique :

- le fonctionnement des ACL (ir.model.access),
- l'association des droits aux groupes,
- les bonnes pratiques pour éviter une exposition excessive des modèles.

2. Mise en place de Record Rules pour limiter l'accès aux données

Les Record Rules permettent de restreindre l'accès aux enregistrements selon l'utilisateur, le groupe ou la société, même lorsqu'un accès au modèle est autorisé.

Documentation officielle Odoo :

- Odoo – Record Rules (section sécurité backend)
<https://www.odoo.com/documentation/19.0/fr/developer/reference/backend/security.html>

Guide pratique complémentaire :

- SerpentCS – Users, Groups, Access Rights and Record Rules in Odoo
<https://www.serpentcs.com/blog/odoo-module-487/users-groups-access-rights-and-record-rules-in-odoo-230>

Ce guide présente :

- des exemples concrets de Record Rules,
- la configuration via l'interface Odoo,
- l'impact sur les utilisateurs internes.

3. Implémentation des règles de sécurité dans les modules Odoo

Lorsque des modules personnalisés ou tiers sont utilisés, les règles de sécurité doivent être définies directement dans le code du module.

Documentation développeur Odoo :

- Odoo – HowTo ACL & Record Rules (Developer Training)
https://www.odoo.com/documentation/15.4/developer/howtos/rdtraining/B_acl_irrules.html

Cette ressource détaille :

- la définition des ACL via les fichiers CSV,
- la création de Record Rules XML,
- les bonnes pratiques de développement sécurisé.

4. Sécurisation des accès API et RPC (XML-RPC / JSON-RPC)

Les accès API doivent être limités aux cas d'usage nécessaires et sécurisés via des mécanismes adaptés (API keys, restriction des méthodes exposées).

Guide de bonnes pratiques API Odoo :

- Odoo API Integration Guide (API Keys & Security)
<https://www.getknit.dev/blog/odoo-api-integration-guide-in-depth>

Cette ressource explique :

- l'utilisation des clés API au lieu des identifiants classiques,
- la réduction de la surface d'attaque RPC,
- les bonnes pratiques d'authentification et de chiffrement.

5. Ressources pédagogiques et supports visuels (annexes)

Ces ressources peuvent être utilisées pour la mise en œuvre opérationnelle ou la formation des équipes techniques.

- Odoo Security – Record Rules (vidéo explicative)
<https://www.youtube.com/watch?v=LoXZk52aZVU>
- Odoo Access Control & Groups (vidéo explicative)
https://www.youtube.com/watch?v=mzg3EGD_6Gw&utm_source=chatgpt.com

Conclusion

L'accès aux modèles et aux données observé ne résulte pas d'un usage normal de la plateforme, mais d'un défaut de segmentation des droits utilisateurs. Même dans un contexte interne, un utilisateur authentifié ne doit accéder qu'aux données strictement nécessaires à ses fonctions.

Cette vulnérabilité est classée comme ÉLEVÉE à CRITIQUE, compte tenu de l'impact et de la facilité d'exploitation.